

utes lead some analysts to predict that Slammer may very well be the first of many such swiftly spreading worms that could use enormously destructive payloads.

Slammer's origins have remained unknown—the small size of the worm ensured there was no additional information about the worm in the code, and has made it hard to trace its origin.

Red is the colour

Back in June 2001, security professionals detected a vulnerability in Microsoft's IIS 4 and 5, running on Windows NT, 2000, and beta versions of Windows XP. The flaw here was a gaping hole in the Indexing Services of IIS 4 and 5, another remotely exploitable buffer overflow problem; any intruder who could reach a vulnerable Web server could execute arbitrary code and eventually gain complete access to the system. Microsoft released a patch that addressed this problem. Those who didn't patch up quickly enough, faced a new worm around July 12th, one that exploited the IIS vulnerability to the hilt. The worm called Code Red attacks by attempting to connect to TCP port 80 of a randomly chosen host. The 4 KB sized worm passes a carefully constructed URI (Uniform Resource Identifier) to the HTTP service (a 'GET' request). If the system is vulnerable, the request will almost certainly exploit the buffer overflow vulnerability in the system, and allow the code to execute.

The worm came with some pretty good smarts programmed in. It first spawned 100 threads, thus running a 100 copies of the worm at that time. It then followed a fixed timetable—between the 1 to 19 days of the month, it would try to infect other hosts. From the 28th day to the end of the month, the worm would go to sleep. The

real action would happen between the 20th and the 27th day, when the worm would launch a packet flooding DoS attack on the IP address 198.137.240.91. At that point of time, that IP address was assigned to the official Web site of the US Presidential office. The worm also affected certain Cisco routers, triggering off an unrelated vulnerability. The DoS attack on the White House site was performed by sending 98,304 packets to the whitehouse.gov server. Now, all 100 threads of the worm can take part in this attack, giving rise to 100 times 98,304 packets every four-and-a-half hours, after which the worm slept. Finally, the 100th worm thread defaces the server with a message saying it had been hacked by the Chinese.

The only indicator of the abnormal activity of DoS is unusually high traffic. Code Red could be swept off a system if the system is rebooted. The problem is that since all the Code Red infected systems scan the same IP addresses, they tend to re-infect as soon as the computer comes online again.

But that's where Code Red was flawed—its random number generator was not perfect, and so, identical lists of seemingly random target IP addresses across different machines were created. This meant that the worm spread rather slowly, probing and scanning infected or invulnerable machines.

Code Red was followed by a smarter Code Red v2, the CRv2 worm. CRv2 came with a far more sophisticated random seed so that each infected computer came up with different lists of random IP addresses to target; this vital difference in code allowed CRv2 to infect so many machines that world-wide traffic in the third week of July 2001 slowed down considerably. Also, CRv2 was so smart that it no longer hard

Am I at Risk?

Yes, you are. You may be just a home user with a cable, DSL or an always-on pipe to the Internet, but even if you don't run a site, your computer could still be an unwilling participant in a DDoS attack as a zombie, spewing out packets in an effort to snuff out another site. Moreover, this also leaves the data in your computer very vulnerable to the tender mercies of a cracker. What can you do? Take all the basic precautions—use a strong firewall and anti-virus solution, don't install software whose authenticity you can't verify, and be sure to keep track of and install all the important updates, at least the security related ones, that might prevent your computer from being 'acquired'.

coded the White House's Web site address—it queried a DNS and looked up the address.

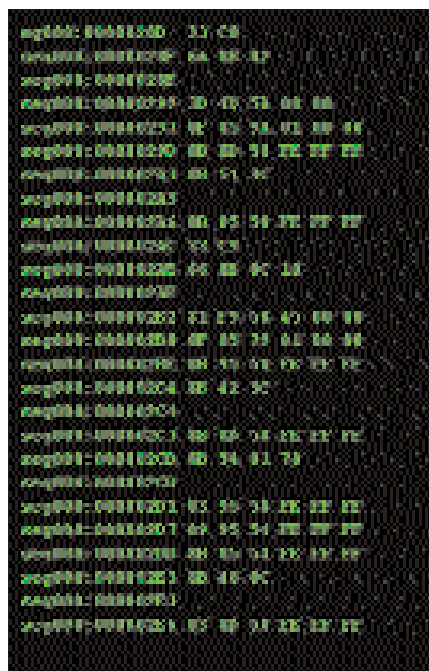
In August of 2001, yet another worm came out into the wild. This one was called CodeRedII; it was unrelated to the first two, but used the same vulnerability in the IIS servers. This was no mean worm—unlike the first two, CodeRedII was not memory resident, so a mere reboot would not help. After infection, it initiates propagation, and then opens up a backdoor and remains dormant for a day. Intriguingly, the worm does no damage to any files or Web pages—instead, the

Know Thy Enemy

It looks like just about any computer on the Internet, with a standard OS and offering standard services, but with one difference: it's a honey pot. Honey pots have been designed to appear as attractive options to crackers, the sort that they just can't seem to ignore. They appear to be a normal machine to the cracker; loaded with what appears to be genuine data the cracker can explore. Meanwhile, the good guys are busy using the honey pot to trace the hacker and learn more about the

compromised aspects of the system as well as how the hacker probes the computer.

An extension of this is the HoneyNet project that uses several systems over a network. In the network, inbound and outbound connections are analysed, informing users about the kinds of intrusions that take place. The HoneyNet provides services very similar to a production system, making it appear genuine. The HoneyNet project is located at <http://project.honeynet.org/>



Code Red: lying silent and waiting